

Cyber Threat Intelligence

Executive Briefing

Report Date: July 05, 2026

Generated: 2026-07-05 22:43 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	11	4	1	20

2. Executive Summary

As of July 05, 2026, the security operations center has concluded an assessment of 20 identified vulnerabilities, categorized by severity as 4 Critical, 11 High, 4 Medium, and 1 Low. The current organizational risk posture is classified as critical, primarily driven by persistent exposure within our internal server infrastructure and authentication mechanisms. The most significant threat is CVE-2026-49360, Unauthenticated SQL Injection in Recce Server, which represents the highest priority due to the potential for direct, unauthorized interaction with the underlying database without authentication. Immediate remediation efforts must prioritize the patching of all Critical and High findings to neutralize the threat of unauthorized system access. The recommended posture is an immediate transition to a state of heightened vigilance with accelerated deployment of compensating controls where patching is not immediately feasible.

3. Critical Action List

- Immediate patching and verification of CVE-2026-49360 (Recce Server SQL Injection) must be completed within 24 hours.
- Perform an emergency rotation of all authentication secrets for the 9router application to address CVE-2026-49352 within 24 hours.
- Restrict network access to LaunchServer and implement file system hardening to mitigate CVE-2026-54617 by July 06, 2026.
- Revoke and re-issue all bearer tokens associated with the fast-mcp-telegram integration to remediate CVE-2026-52830 within 48 hours.
- Apply network-level micro-segmentation to Steeltoe management ports to prevent unauthorized access per CVE-2026-50194 within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-49360	Unauthenticated SQL Injection in ...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	Authentication Bypass via Default...	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Unauthenticated Path Traversal in...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Bearer Token Path Traversal in fa...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Management Port Isolation Bypass ...	8.2	High	74/100	CWE-288
CVE-2026-2092	Unauthorized SAML Assertion Acces...	7.7	High	69/100	CWE-1287
CVE-2026-49353	Host Header Injection Bypass in 9...	7.5	High	68/100	CWE-290
CVE-2026-46599	DoS via PackBits Decompression in...	7.5	High	68/100	CWE-770
CVE-2026-52792	Server-Side Script Source Disclos...	7.5	High	68/100	CWE-69
CVE-2026-50200	Sensitive Data Leakage in Steelto...	7.5	High	68/100	CWE-200
CVE-2026-50196	Registry Fetch Poisoning in Steel...	7.5	High	68/100	CWE-20
CVE-2026-49289	Denial-of-Service via XPath Trans...	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Crash in Zebra Address Bo...	7.5	High	68/100	CWE-617
CVE-2026-52834	Integer Overflow Out-of-Bounds Wr...	8.6	High	66/100	CWE-122
CVE-2026-49284	Improper SAML Response Validation...	7.5	High	64/100	CWE-345
CVE-2026-50201	Insecure Actuator Access in Steel...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	JWKS Cache Poisoning in Steeltoe	5.9	Medium	53/100	CWE-668
CVE-2026-50267	Insecure TLS Key Storage in Steel...	4.7	Medium	42/100	CWE-312
CVE-2026-49292	Unauthorized Access to Kiwi TCMS ...	6.5	Medium	39/100	CWE-862
CVE-2026-50268	Insecure Padding Selection in Ste...	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: Unauthenticated SQL Injection in Recce Server

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server's API endpoint exposes an unauthenticated SQL execution path facilitating interaction with the DuckDB database engine. The vulnerability stems from improper input sanitization of user-supplied commands before

passing them to the database driver. This flaw allows an unauthenticated remote attacker to perform arbitrary local file read and write operations, resulting in complete system compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specifically crafted HTTP request to the Recce server's database interface. The request contains malicious SQL syntax targeting the DuckDB instance via the exposed execution method. The server fails to validate the input before interpreting it as a command, granting the attacker file system access. This allows the attacker to read sensitive configuration files or overwrite system binaries to achieve persistence.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-49352

Finding: Authentication Bypass via Default JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The 9router application utilizes a hardcoded, default JWT fallback secret in its authentication handler. This vulnerability stems from the developer's failure to enforce dynamic or environment-specific secret keys, allowing any entity to reconstruct valid session tokens. An unauthenticated attacker can forge arbitrary authentication tokens to bypass access controls and assume the identity of any system user.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the default JWT secret through public repository analysis. The attacker crafts a new JWT payload containing administrative claims and signs it using the identified default secret. This forged token is then presented in the Authorization header of a request to the 9router API. The server validates the token against the hardcoded secret, granting the attacker full administrative access.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Unauthenticated Path Traversal in LaunchServer

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The FileServerHandler in LaunchServer contains a path traversal vulnerability that permits unauthorized file access outside of the intended web root. This flaw is due to the lack of proper validation and sanitization of user-provided input within the file request parameters. An unauthenticated remote attacker can navigate the file system to read arbitrary sensitive files, compromising the confidentiality of the host environment.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP GET request to the LaunchServer FileServerHandler with path components like ../../etc/passwd. The server processes the requested path by concatenating it with the base directory without stripping path traversal sequences. The application then reads the contents of the target system file and returns it in the response body. The attacker gains unauthorized access to sensitive system information.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Bearer Token Path Traversal in fast-mcp-telegram

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram integration contains a path traversal vulnerability in its bearer token handling logic that bypasses reserved Telegram session protections. The root cause is a failure to sanitize input used in path construction, allowing an attacker to access protected session directories. An unauthenticated attacker can exploit this to retrieve sensitive authentication tokens, leading to full takeover of Telegram sessions.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request to the fast-mcp-telegram service with a manipulated bearer token parameter containing path traversal characters like ../. The application uses this input to open a file path, breaking out of the designated storage directory and into the protected session management folder. The server returns the content of the Telegram session files to the attacker. The attacker gains the ability to authenticate as the target user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Management Port Isolation Bypass in Steeltoe

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	Low	Availability Impact	None

Description:

Steeltoe fails to enforce port isolation for management endpoints, allowing an attacker to bypass security restrictions using a spoofed Host header. The root cause is a failure in the request routing middleware to verify the origin and port binding of the request before allowing access to management functionality. An attacker can reach protected administration endpoints from an external interface, compromising system security.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request to the public-facing application port with a Host header set to the internal management port address. The Steeltoe routing logic incorrectly interprets this header as a request to the local management interface and bypasses authentication requirements. The attacker receives a response from the management actuator, gaining access to privileged control functions. The system is then vulnerable to unauthorized administrative operations.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: Unauthorized SAML Assertion Access in Keycloak

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1199

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network	Attack Complexity	High
Privileges Required	Low	User Interaction	None
Scope	Changed	Confidentiality Impact	High
Integrity Impact	Low	Availability Impact	Low

Description:

Keycloak suffers from improper validation of encrypted SAML assertions, allowing for unauthorized access to sensitive user attributes. The root cause is a failure in the security provider's assertion decryption workflow that does not strictly

enforce context-bound integrity checks. An authenticated attacker can exploit this to perform cross-tenant data access, leading to confidentiality and integrity loss within the identity provider.

Proof of Concept (PoC):

An authenticated user with low-level access crafts a SAML request that includes an encrypted assertion from a different identity context. Keycloak decrypts the assertion without properly verifying that the assertion target matches the authenticated user's session context. The system processes the assertion and grants the attacker visibility into attributes intended only for other tenants. The attacker successfully exfiltrates sensitive user metadata.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Host Header Injection Bypass in 9router

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1133, T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The 9router gateway component fails to adequately validate the Host header during traffic routing, resulting in an incomplete fix for local-only access controls. This vulnerability arises from the system trusting the user-supplied HTTP Host header when determining if a request originates from an internal source. An remote attacker can spoof this header to bypass network-level security restrictions, gaining unauthorized access to internal management services.

Proof of Concept (PoC):

An unauthenticated remote attacker captures an incoming request to the 9router infrastructure. The attacker modifies the Host header to an internal address or a trusted loopback domain while maintaining the external connection. The router's validation logic incorrectly identifies the request as local traffic and forwards it to protected administrative endpoints. The attacker successfully interacts with these restricted interfaces to retrieve confidential data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: DoS via PackBits Decompression in golang/x/image

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The `golang.org/x/image/tiff` library exhibits excessive resource consumption during the processing of PackBits encoded images. The vulnerability is caused by a failure to limit the expansion ratio of the decompression algorithm, which can be manipulated to trigger memory exhaustion. An attacker can supply a malformed TIFF image to an application using this library, resulting in a denial-of-service condition through memory exhaustion.

Proof of Concept (PoC):

An unauthenticated attacker uploads a specifically crafted TIFF image containing highly compressed PackBits data to an endpoint processed by the vulnerable Go package. The library's decompression routine attempts to allocate large buffers to accommodate the decoded output without bounds checks. The system's memory usage spikes rapidly, forcing the kernel to terminate the process to prevent a system-wide crash. This successfully renders the service unavailable to legitimate users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-52792

Finding: Server-Side Script Source Disclosure in Algernon

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1048

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon server exhibits a vulnerability that allows for the disclosure of server-side script source code when deployed on Windows systems. The issue arises from the way the application processes NTFS alternate data streams or specific filename suffixes, bypassing access controls meant to prevent direct source delivery. An remote attacker can leverage this behavior to view application logic, potentially leaking credentials or hardcoded keys.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a script file served by Algernon on a Windows host. The attacker modifies the requested URL to include specific NTFS filename patterns or encoded characters that the server's file system interface treats as a standard read operation instead of execution. The server returns the raw source code of the script instead of the expected dynamic output. The attacker obtains the full application source code, facilitating further attacks.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50200

Finding: Sensitive Data Leakage in Steeltoe Env Sanitizer

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's environment sanitizer component fails to properly mask connection strings, resulting in the leakage of embedded database passwords in diagnostic output. The root cause is an inadequate regular expression or filtering logic that ignores connection string formatting within the configuration metadata. This vulnerability allows an attacker to gain access to sensitive credentials, compromising the backend data infrastructure.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to an exposed diagnostic actuator that triggers a dump of the application's environment variables. The sanitizer processes the connection strings but fails to identify or mask sensitive password fields. The response contains plaintext credentials embedded in the configuration dump. The attacker parses the response, extracts the database passwords, and gains unauthorized access to the production database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Registry Fetch Poisoning in Steeltoe Eureka

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Steeltoe.Discovery.Eureka component is vulnerable to registry fetch poisoning via unrecognized DataCenterInfo.Name attributes. The root cause is a failure in the registry parser to validate incoming data structures

against expected schemas, leading to process instability. An attacker can inject malformed data to crash the registry fetch process, resulting in denial-of-service for the service discovery mechanism.

Proof of Concept (PoC):

An attacker intercepts or spoofs responses from the Eureka server during the registry registration or fetch phase. The attacker includes a DataCenterInfo.Name attribute that is specifically crafted to trigger an unhandled exception in the client-side parsing logic. The Steeltoe service fails to handle this exception, crashing the service discovery client. This prevents the application from locating critical microservices, effectively disabling the entire distributed system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: Denial-of-Service via XPath Transformation in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service condition during the processing of XML documents using XPath transformations. The root cause is the lack of resource limits on complex XPath queries, which can lead to CPU or memory exhaustion. An attacker can submit a crafted SAML request containing a complex XPath expression, forcing the server to consume excessive resources.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a SAML authentication request to the SimpleSAMLphp SP containing a recursive or deeply nested XPath query. The application passes the XML input to the XPath transformer without applying computational bounds or limits. The server enters an infinite or computationally intensive loop, stalling processing threads. This exhausts server availability and prevents the application from responding to legitimate user requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Crash in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book component exhibits instability caused by misbehavior in its memory pool (mempool) management when processing IPv4-mapped addresses. The root cause is a failure in the memory allocation tracking logic to account for specific address space transitions, leading to memory corruption or crashes. An attacker could exploit this by providing specially crafted network data to induce an application-wide crash.

Proof of Concept (PoC):

An unauthenticated attacker sends a network packet to the Zebra Address Book service containing an IPv4-mapped address that violates internal memory pool assumptions. The application attempts to allocate or free memory in the mempool based on this malformed address, triggering an assertion failure or invalid access. The process immediately terminates, leading to a denial-of-service condition for the address book service. This leaves the system unavailable until a manual restart is performed.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

CVE-2026-52834**Finding: Integer Overflow Out-of-Bounds Write in jxl-grid**

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid component performs unsafe arithmetic operations that lead to an integer overflow when running on 32-bit platforms. This vulnerability is caused by insufficient validation of grid dimensions before memory allocation, allowing for an out-of-bounds write during grid population. An attacker can craft a specific input that triggers this overflow, leading to arbitrary memory corruption and potentially remote code execution.

Proof of Concept (PoC):

An attacker sends a malicious data payload to a service utilizing jxl-grid that defines grid dimensions calculated to cause an integer wrap-around. The internal memory allocation routine uses the wrapped value, which is smaller than the required buffer size for the provided data. The subsequent write operation spills over into adjacent memory blocks, corrupting control data or executable structures. The attacker leverages this memory corruption to control the

application's execution flow.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: Improper SAML Response Validation in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1136

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The SimpleSAMLphp Service Provider (SP) improperly validates SAML responses when an unsigned Response/InResponseTo is paired with a signed assertion lacking specific SubjectConfirmationData checks. This vulnerability stems from a logic flaw in the signature verification process which fails to ensure the binding between the assertion and the response is secure. An attacker could exploit this by presenting a fraudulent assertion from an unexpected Identity Provider, leading to unauthorized account access.

Proof of Concept (PoC):

An attacker creates a malicious SAML assertion signed by an attacker-controlled Identity Provider. The attacker lures an authenticated user to perform an action that triggers a SAML flow, injecting the fraudulent response instead of the legitimate one. SimpleSAMLphp fails to properly verify the origin of the assertion and the InResponseTo ID, mapping the attacker's assertion to the victim's session. The attacker successfully hijacks the victim's authentication context.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

CVE-2026-50201

Finding: Insecure Actuator Access in Steeltoe

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: CNA Official

MITRE ATT&CK: T1082

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe exposes sensitive management actuators, such as heapdump and environment details, to users with only restricted privileges. The root cause is a failure in the role-based access control (RBAC) middleware to distinguish between basic user access and administrative management functions. An authenticated user can leverage these endpoints to exfiltrate sensitive environment variables and system state data.

Proof of Concept (PoC):

An authenticated user with low privileges sends a GET request to the /actuator/env or /actuator/heapdump endpoints. The application authorizes the request because the user has active, but insufficient, session credentials. The server returns the requested diagnostic information, including sensitive database connection strings and system configurations. The attacker uses this leaked information to conduct more advanced attacks.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: JWKS Cache Poisoning in Steeltoe

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official
MITRE ATT&CK: T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	High
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

Steeltoe utilizes a shared static cache for JSON Web Key Sets (JWKS) that lacks proper tenant or scheme-based isolation. The root cause is a flawed cache-key generation mechanism in the security handler that ignores the context of the authentication request. An attacker with high privileges can poison this cache, affecting the verification of tokens across the entire application instance.

Proof of Concept (PoC):

A high-privileged administrator modifies the application configuration to force a reload of the JWKS endpoint, providing a malicious set of keys. The global cache is updated with the attacker-controlled keys, which are then used to validate tokens for unrelated authentication schemes. Any user attempting to log in subsequently has their token validated against the malicious key, allowing the attacker to bypass authentication. This facilitates large-scale identity spoofing within the system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-50267

Finding: Insecure TLS Key Storage in Steeltoe

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe writes sensitive TLS private keys to the /tmp directory with default permissions and fails to remove them after use. The root cause is a failure in the ephemeral file management logic of the TLS configuration module. A local attacker can access these files to gain unauthorized possession of private cryptographic keys, compromising the confidentiality of secure communications.

Proof of Concept (PoC):

A local attacker with low-level privileges monitors the /tmp directory for new files created by the Steeltoe application process. The attacker observes that private keys are written to disk during the service's TLS initialization phase. The attacker copies these files before the service completes its task, as the file permissions remain world-readable. The attacker can then impersonate the service in future network interactions.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-49292

Finding: Unauthorized Access to Kiwi TCMS Database Init

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Kiwi TCMS /init-db/ page remains accessible and functional even after the initial application deployment and configuration process. This vulnerability is caused by a failure to revoke access to the installation endpoint, which does not check for existing state completion. An attacker can access this page to potentially disclose system metadata or influence database initialization, violating integrity and confidentiality assumptions.

Proof of Concept (PoC):

An unauthenticated remote attacker navigates to the /init-db/ URL on a production-deployed instance of Kiwi TCMS. The application responds by rendering the page and accepting input, despite the application having been previously

configured. The attacker can then view internal database configuration details or potentially trigger re-initialization routines. This provides the attacker with a window into the internal setup of the application environment.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50268

Finding: Insecure Padding Selection in Steeltoe

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local	Attack Complexity	High
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	None	Availability Impact	None

Description:

Steeltoe fails to correctly enforce cryptographic requirements, silently selecting PKCS#1 v1.5 padding when OAEP is requested. The root cause is an insecure default configuration in the crypto-wrapper component that ignores explicit padding settings. A local attacker with high privileges could exploit this to perform side-channel attacks on encrypted material, potentially recovering sensitive cryptographic keys.

Proof of Concept (PoC):

A privileged local attacker monitors cryptographic operations performed by the Steeltoe service. The attacker captures encrypted ciphertexts intended for processing with OAEP padding. Due to the silent fallback to PKCS#1 v1.5, the attacker leverages known padding oracle vulnerabilities to decrypt the ciphertexts. This allows the attacker to recover plaintext information or partially reconstruct session keys.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found

live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>